

Overview

Project Summary

Project Name	Workspace Strategy Manager
Language	Rust (Anchor Framework)

Audit Summary

Delivery Date	April 27, 2026 UTC
Audit Methodology	Static Analysis, Manual Review

Vulnerability Summary

Vulnerability Level	Total
Critical	1
Major	1
Medium	1
Minor	1

Table of Contents

Summary

Overview

Project Summary

Audit Summary

Vulnerability Summary

Audit Scope (Scope includes all provided Rust files)

Findings

Finding-01 : Missing Account Relationship Constraint on Config

Finding-02 : Yield is Locked and Prevents Position Closure

Finding-03 : Token Vaults Are Not Closed on Position Closure

Finding-04 : Incomplete Liquidity Calculation in Rebalance Stub

Findings

4 Total Issues

Title	Category	Severity
Missing Account Relationship Constraint on Config	Access Control	Critical
Yield is Locked and Prevents Position Closure	Logical Issue	Major
Token Vaults Are Not Closed on Position Closure	State Management	Medium
Incomplete Liquidity Calculation in Rebalance Stub	Logical Flaw	Minor

Missing Account Relationship Constraint on Config

Category	Access Control
Severity	Critical

Description

In the `Deposit`, `Rebalance`, and `EmergencyWithdraw` instruction contexts, the program fetches a `StrategyConfig` account to enforce global settings such as pause states and slippage limits. However, there is no constraint verifying that the passed `config` account is the actual configuration account tied to the user's `PositionState` (`position.config`).

Because any user can initialize a new valid `StrategyConfig` via the `initialize_config` instruction, an attacker or a rogue keeper can create a spoofed config account. By passing this spoofed config, they can bypass the `is_paused` check to perform deposits while the protocol is paused, bypass `max_slippage_bps` during rebalancing, or force arbitrary users into an `emergency_withdraw` (a griefing attack).

Recommendation

It is recommended to enforce a strict relationship between the position and the configuration account. Ensure that the configuration account passed into the instruction context explicitly matches the public key stored in the position's state account. This will guarantee that global protocol constraints cannot be bypassed by supplying unauthorized configuration PDAs.

Yield is Locked and Prevents Position Closure

Category	Logical Issue
Severity	Major

Description

The `withdraw` instruction restricts users from withdrawing amounts greater than their initially recorded `total_deposited_a` and `total_deposited_b` balances. If the position is profitable and accrues yield within the token vaults, this accumulated profit cannot be withdrawn by the user.

Furthermore, the `ClosePosition` instruction enforces a strict constraint that both token vault amounts must be exactly zero before the position account can be closed. Because the trapped yield prevents the vault balances from ever reaching zero, a profitable position can never be fully closed, permanently locking both the yield and the rent-exempt lamports associated with the strategy accounts.

Recommendation

It is recommended to implement a yield realization mechanism. Adjust the withdrawal logic to allow users to withdraw their proportional share of the entire vault balance rather than capping it strictly at the principal deposited amount. Additionally, reconsider the closing requirements to either allow sweeping of fractional residual amounts or proper liquidation of the total position balance to the user.

Token Vaults Are Not Closed on Position Closure

Category	State Management
Severity	Medium

Description

During the `close_position` instruction, the primary `PositionState` PDA is properly closed and its lamports are refunded to the owner. However, the program fails to close the associated `vault_token_a` and `vault_token_b` accounts.

Because these token accounts belong to the program's PDA, only the program can close them via a Cross-Program Invocation (CPI) to the SPL Token program. Since this step is omitted, the empty token accounts are left orphaned on the network, leading to permanent state bloat and a complete loss of the rent-exemption SOL deposited into those vaults.

Recommendation

It is recommended to invoke the SPL Token program's close account instruction for both token vaults within the position closure logic. Use the position PDA's signer seeds to authorize the closure, and set the designated owner account to receive the reclaimed rent-exemption lamports.

Incomplete Liquidity Calculation in Rebalance Stub

Category	Logical Flaw
Severity	Minor

Description

In the `rebalance` instruction, the calculations for `center_liquidity` and `wing_liquidity` rely exclusively on the `total_deposited_a` variable. The protocol entirely ignores `total_deposited_b` when determining the total liquidity available for distribution.

While the current implementation operates primarily as a stub for off-chain keeper interactions, deploying this localized math will result in deeply skewed position sizing, as an entire side of the token pair is omitted from the underlying mathematical models.

Recommendation

It is recommended to incorporate both deposited token assets when modeling concentrated liquidity allocations. Integrate proper liquidity mathematical formulas that convert both Token A and Token B reserves into appropriate liquidity units before determining allocation percentages.

Summary

This report summarizes the security assessment of the Workspace Strategy Manager Solana Program written in Rust using the Anchor framework. The assessment involved a comprehensive examination of the provided source code using Static Analysis and Manual Review techniques.

The audit focused on identifying potential vulnerabilities, logical flaws, and adherence to Solana and Anchor best practices. Key areas of focus included:

- Account validation and access control.
- Handling of token transfers and CPI calls.
- State management, PDA constraints, and data integrity.
- Financial logic governing deposits, withdrawals, and yield.

The assessment identified several high-priority issues that require immediate remediation. The most critical vulnerability involves the lack of relationship mapping between a user's position and the protocol's configuration account, allowing malicious actors to bypass essential admin controls and execute griefing attacks. A major issue was also discovered within the withdrawal logic, which inadvertently locks generated yield within the strategy vaults and completely prevents users from closing profitable accounts.

Additionally, medium and minor architectural issues were noted regarding incomplete cleanup of token accounts (causing rent leaks) and logically incomplete mathematical models for concentrated liquidity allocation.

Addressing the outlined vulnerabilities, particularly ensuring proper account validation constraints and refactoring the withdrawal limit logic, is vital for safeguarding user funds and guaranteeing the program operates securely as intended.

Disclaimer

For the purposes of this disclaimer:

- "*Noah AI*" refers to the product currently operated by its owners and developers, including but not limited to its creators, contributors, affiliates, officers, employees, contractors, and agents.
 - "*Plena*" refers to Plena Finance Digital LLC, including but not limited to its affiliates, officers, employees, contractors, and agents.
 - "*User*" refers to the recipient of this report, whether an individual or an entity, and any of its affiliates, officers, employees, contractors, or agents who access, review, or act upon the contents of this report.
-

AI-Generated Content

This report is *entirely generated by artificial intelligence (AI)* without human authorship, review, or verification by Noah AI or Plena. AI-generated content is inherently probabilistic and may contain inaccuracies, false positives, or false negatives. *The User is solely and fully responsible* for reviewing, verifying, and validating all information before relying on it or taking any action.

No Responsibility or Liability

To the maximum extent permitted by law, *Noah AI and Plena, and their respective owners, operators, affiliates, officers, employees, contractors, and agents*, **accept no responsibility or liability** for:

- The accuracy, completeness, legality, reliability, or security of this report
 - Any hacks, exploits, unauthorized access, security breaches, or vulnerabilities
 - Any loss of funds, data, or digital assets
 - Any direct, indirect, incidental, consequential, punitive, or special damages of any kind, *whether in contract, tort, or otherwise*, even if advised of the possibility of such damages
-

No Endorsement or Advice

Nothing in this report constitutes or should be interpreted as an endorsement, recommendation, disapproval, investment advice, financial advice, legal advice, or guarantee of performance.

No Guarantee of Regulatory Compliance

Nothing in this report constitutes a guarantee by Noah AI or Plena of regulatory compliance, legal validity, or adherence to applicable laws in any jurisdiction.

No Contract Formation

Use of this report does not create any contractual obligations between the User and Noah AI, Plena, or their respective owners, beyond those explicitly stated in a written agreement between the parties.

Third-Party Dependencies

References to third-party technologies, services, or platforms are for informational purposes only and do not constitute endorsements or assurances by Noah AI or Plena of their reliability, security, or legality.

Risk Disclaimer

Blockchain technology, AI systems, and cryptographic assets are highly experimental and carry substantial risks. The User remains solely responsible for conducting independent due diligence, obtaining professional advice, and ensuring compliance with all applicable laws and regulations before acting on any information in this report.